

answer the following questions according to their marking structure:

Section A (Compulsory)

Q1. Answer all the following sub-questions. (Total 30 Marks)

- a) Explain the components of the CIA Triad and the two extended security objectives required for a complete framework. (4 Marks) b) Distinguish between Passive and Active security attacks, providing one example of each. (4 Marks) c) State the primary differences in operation and reliability between TCP and UDP at the Transport Layer. (3 Marks) d) What is the purpose of IP Subnetting and Classless Inter-Domain Routing (CIDR)? (4 Marks) e) Differentiate between a Bridge and a Router concerning the OSI layer they operate on and their handling of broadcast domains. (3 Marks) f) Define False Rejection Rate (FRR) and False Acceptance Rate (FAR) in the context of evaluating biometric systems. (4 Marks) g) Contrast a True Positive with a False Positive in the context of an Intrusion Detection System's behavior-based anomaly detection. (4 Marks) h) Briefly compare the regulatory scope of the HIPAA/HITECH Act and the PCI DSS standard. (4 Marks)

Gemini 3.1 Pro Extended

Here are the answers to the questions, structured to align directly with the requested marking weight for each item.

Section A (Compulsory)

a) Explain the components of the CIA Triad and the two extended security objectives required for a complete framework. (4 Marks)

- **Confidentiality (1 Mark):** Ensuring that sensitive information is only accessible to authorized individuals, processes, or systems (e.g., through encryption or access controls).
- **Integrity (1 Mark):** Safeguarding the accuracy and completeness of data by preventing unauthorized modifications, deletions, or fabrications.
- **Availability (1 Mark):** Ensuring that network resources, data, and systems are reliably accessible to authorized users whenever needed without disruption.
- **Extended Objectives (1 Mark):** * *Authenticity:* Verifying that users are exactly who they claim to be and that data originates from a trusted source.
 - *Non-repudiation:* Ensuring that a party involved in a communication or transaction cannot later deny their participation or the origin of the data.

b) Distinguish between Passive and Active security attacks, providing one example of each. (4 Marks)

- **Passive Attacks (2 Marks):** The attacker eavesdrops on or monitors transmissions to gather sensitive information without altering system resources or affecting normal operations. Because data isn't changed, these are difficult to detect.
 - *Example:* Packet sniffing or traffic analysis.
- **Active Attacks (2 Marks):** The attacker actively modifies data streams, alters system resources, or creates false data streams, directly disrupting normal system operations.

- *Example:* Denial of Service (DoS) attacks, Man-in-the-Middle (MitM) modification, or session hijacking.

c) State the primary differences in operation and reliability between TCP and UDP at the Transport Layer. (3 Marks)

- **Operation (1.5 Marks):** TCP (Transmission Control Protocol) is *connection-oriented*, meaning it establishes a formal session via a three-way handshake before sending data. UDP (User Datagram Protocol) is *connectionless* and simply sends packets without establishing a prior session.
- **Reliability (1.5 Marks):** TCP is highly *reliable*; it uses sequence numbers and acknowledgments to ensure guaranteed, in-order delivery and retransmits lost packets. UDP is *unreliable* (best-effort); it does not check for lost packets or ensure sequence order, making it faster but prone to data loss.

d) What is the purpose of IP Subnetting and Classless Inter-Domain Routing (CIDR)? (4 Marks)

- **IP Subnetting (2 Marks):** The logical practice of dividing a single large IP network into multiple smaller, manageable network segments (subnets). Its purpose is to reduce broadcast traffic, improve network performance, and isolate network segments for better security.
- **CIDR (2 Marks):** A flexible method of IP addressing that replaces the rigid, legacy Class A/B/C system. Its purpose is to slow the exhaustion of IPv4 addresses and shrink global routing tables by allowing networks to be sized precisely using variable-length subnet masks (e.g., `/24` or `/26`).

e) Differentiate between a Bridge and a Router concerning the OSI layer they operate on and their handling of broadcast domains. (3 Marks)

- **OSI Layer (1 Mark):** A Bridge operates at the Data Link Layer (Layer 2), while a Router operates at the Network Layer (Layer 3).
- **Broadcast Domains (2 Marks):** A Bridge filters MAC addresses to separate *collision* domains but forwards broadcast traffic, meaning it keeps all connected segments in the *same* broadcast domain. A Router drops broadcast traffic by default, actively separating and defining *different* broadcast domains.

f) Define False Rejection Rate (FRR) and False Acceptance Rate (FAR) in the context of evaluating biometric systems. (4 Marks)

- **False Rejection Rate (FRR) (2 Marks):** Also known as a Type I error. It is the probability that a biometric system incorrectly rejects access to a legitimate, authorized user. A high FRR causes friction and frustrates legitimate users.
- **False Acceptance Rate (FAR) (2 Marks):** Also known as a Type II error. It is the probability that a biometric system incorrectly grants access to an unauthorized, illegitimate user. A high FAR represents a severe security vulnerability.

g) Contrast a True Positive with a False Positive in the context of an Intrusion Detection System's behavior-based anomaly detection. (4 Marks)

- **True Positive (2 Marks):** The IDS operates correctly by successfully identifying and generating an alert for actual malicious activity or a genuine security anomaly.
- **False Positive (2 Marks):** The IDS fails by incorrectly flagging benign, normal user behavior or routine network traffic as a malicious anomaly. High rates of false positives lead to "alert fatigue" for security analysts.

h) Briefly compare the regulatory scope of the HIPAA/HITECH Act and the PCI DSS standard. (4 Marks)

- **HIPAA/HITECH Act (2 Marks):** A US federal law whose scope is strictly limited to the healthcare sector. It mandates the protection, privacy, and secure handling of Protected Health Information (PHI) by healthcare providers, clearinghouses, and business associates.
- **PCI DSS (2 Marks):** A global industry standard (not a government law) governed by major credit card brands. Its scope covers *any* organization, regardless of industry, that accepts, processes, stores, or transmits credit cardholder data (CHD).

Section B

Each question carries 15 marks.

Q2. a) Discuss the overall block structure of the Advanced Encryption Standard (AES) algorithm and explain the cryptographic significance of the Avalanche Effect. (7 Marks) b) Describe the internal mechanics and the specific cryptographic rationale behind the MixColumns and ShiftRows transformations in AES. (8 Marks)

Q3. a) Outline the mathematical steps involved in the key generation, encryption, and decryption phases of the RSA Public-Key Encryption Algorithm. (8 Marks) b) Explain how the RSA algorithm is vulnerable to Timing Attacks and Chosen Ciphertext Attacks (CCA), and detail the modern countermeasures used to mitigate them. (7 Marks)

 Gemini 3.1 Pro Extended

Here are the detailed answers for Section B, structured to align directly with the requested 15-mark distribution for each question.

Section B

Q2. a) Discuss the overall block structure of the Advanced Encryption Standard (AES) algorithm and explain the cryptographic significance of the Avalanche Effect. (7 Marks)

- **AES Overall Block Structure (4 Marks):**
 - AES is a symmetric-key block cipher that operates on fixed block sizes of 128 bits.
 - The 128-bit input block is organized into a 4×4 matrix of bytes known as the **State array**. All internal operations are performed on this State.
 - Depending on the key length used (128, 192, or 256 bits), the algorithm executes a specific number of processing rounds: 10, 12, or 14 rounds, respectively.
 - Except for the final round, each standard round consists of four sequential transformations: **SubBytes** (substitution), **ShiftRows** (permutation), **MixColumns** (mixing), and **AddRoundKey** (key addition). The final round skips the MixColumns step.
- **Avalanche Effect and its Cryptographic Significance (3 Marks):**
 - **Definition:** The Avalanche Effect occurs when a minuscule change in the input (changing just one bit of the plaintext or the secret key) results in a drastic, catastrophic change in the output ciphertext (statistically flipping about 50% of the bits).
 - **Significance:** It ensures high non-linearity and effectively destroys any statistical correlation between the plaintext and the ciphertext. If a cipher lacks this property, attackers can use statistical analysis or differential cryptanalysis to deduce the key or plaintext. The Avalanche Effect ensures that brute-forcing remains the only viable attack on the cipher's structure.

Q2. b) Describe the internal mechanics and the specific cryptographic rationale behind the MixColumns and ShiftRows transformations in AES. (8 Marks)

- **ShiftRows (4 Marks):**

- *Internal Mechanics (2 Marks):* This is a byte-level, cyclical permutation operating on the rows of the 4×4 State array. The first row (Row 0) is left unchanged. The second row (Row 1) is circularly shifted one byte to the left. The third row (Row 2) is shifted two bytes to the left, and the fourth row (Row 3) is shifted three bytes to the left.
- *Cryptographic Rationale (2 Marks):* ShiftRows provides crucial **diffusion** across the columns. By shifting the rows differently, it ensures that the four bytes of one column are spread out to four different columns. This prevents independent column processing and breaks up byte alignments.

- **MixColumns (4 Marks):**

- *Internal Mechanics (2 Marks):* This transformation operates on the columns of the State array individually. Each column is treated as a four-term polynomial over the Galois Field $GF(2^8)$ and multiplied by a fixed matrix using modular arithmetic.
- *Cryptographic Rationale (2 Marks):* MixColumns provides major **diffusion within** the column. It ensures that every output byte in a column is a complex mathematical combination of all four input bytes of that column. When combined with ShiftRows, it guarantees that after just a few rounds, every bit of the ciphertext depends on every bit of the plaintext and the key.

Q3. a) Outline the mathematical steps involved in the key generation, encryption, and decryption phases of the RSA Public-Key Encryption Algorithm. (8 Marks)

- **Phase 1: Key Generation (4 Marks):**

1. Choose two large, distinct prime numbers, p and q .
 2. Compute the modulus $n = p \times q$. (This value is used in both the public and private keys).
 3. Compute Euler's totient function: $\phi(n) = (p - 1)(q - 1)$.
 4. Select a public exponent e such that $1 < e < \phi(n)$ and e is coprime to $\phi(n)$ (meaning $\gcd(e, \phi(n)) = 1$).
 5. Compute the private exponent d as the modular multiplicative inverse of e modulo $\phi(n)$. This satisfies the equation $d \equiv e^{-1} \pmod{\phi(n)}$, or $(d \times e) \pmod{\phi(n)} = 1$.
- *Result:* Public Key = (e, n) ; Private Key = (d, n) .

- **Phase 2: Encryption (2 Marks):**

- Given a plaintext message M (where $0 \leq M < n$), the sender uses the receiver's public key (e, n) to compute the ciphertext C :
- $C \equiv M^e \pmod{n}$

- **Phase 3: Decryption (2 Marks):**

- The receiver uses their private key exponent d to recover the plaintext M from the ciphertext C :
- $M \equiv C^d \pmod{n}$

Q3. b) Explain how the RSA algorithm is vulnerable to Timing Attacks and Chosen Ciphertext Attacks (CCA), and detail the modern countermeasures used to mitigate them. (7 Marks)

- **Timing Attacks (3.5 Marks):**

- *Vulnerability (2 Marks):* A timing attack is a side-channel attack where an adversary carefully measures the exact time a system takes to perform the $C^d \pmod{n}$ decryption operation. Because the modular exponentiation process often takes slightly different amounts of time depending on whether a bit in the private key d is a 1 or a 0, an attacker can theoretically reconstruct the private key bit-by-bit by analyzing these time variances.
- *Countermeasure (1.5 Marks):* The primary mitigation is **RSA Blinding**. Before decryption, the ciphertext is multiplied by a random number (the blind). The system decrypts this modified, random-looking value, and the random factor is

mathematically removed afterward. Because the system is processing a random value, the computation time is decoupled from the actual ciphertext, rendering timing analysis useless.

- **Chosen Ciphertext Attacks (CCA) (3.5 Marks):**

- *Vulnerability (2 Marks):* "Textbook RSA" is mathematically malleable. An attacker can intercept a valid ciphertext C , multiply it by a crafted value (like 2^e), and send it to the victim. If the victim decrypts this garbage data and returns an error or the modified plaintext, the attacker can use algebraic relationships to deduce the original plaintext M without ever knowing the private key.
- *Countermeasure (1.5 Marks):* The standard mitigation is the use of structured padding schemes, most notably **Optimal Asymmetric Encryption Padding (OAEP)**. OAEP introduces formatted randomness into the plaintext before it is encrypted. This destroys the mathematical malleability of RSA and ensures that if a ciphertext is altered in transit, it will fail the padding format check upon decryption, causing the system to reject it safely without leaking information.

You Asked 

Q4. a) Elaborate on the key advantages of IPv6 over IPv4, and describe the mechanisms behind the 6to4 and Teredo tunneling techniques. (8 Marks)b) Compare the filtering criteria and defensive mechanisms of basic Packet Filtering Firewalls versus Stateful Inspection Firewalls. (7 Marks)

Q5. a) Contrast Mandatory Access Control (MAC) with Discretionary Access Control (DAC), specifically highlighting how each model handles the threat of malware execution. (7 Marks)b) Describe how Digital Signatures provide non-repudiation and explain the structure of the Hierarchical and Mesh PKI Trust Models. (8 Marks)

Gemini 3.1 Pro Extended

Here are the detailed answers for the continuation of Section B, structured to align directly with the requested 15-mark distribution for each question.

Section B (Continued)

Q4. a) Elaborate on the key advantages of IPv6 over IPv4, and describe the mechanisms behind the 6to4 and Teredo tunneling techniques. (8 Marks)

- **Key Advantages of IPv6 over IPv4 (4 Marks):**

- *Massive Address Space:* IPv6 uses 128-bit addresses (compared to IPv4's 32-bit), practically eliminating the risk of IP exhaustion and removing the need for Network Address Translation (NAT).
- *Simplified Header Format:* IPv6 streamlines the packet header by removing unnecessary fields and checksums, which significantly reduces processing overhead for routers and improves routing efficiency.
- *Stateless Address Autoconfiguration (SLAAC):* Devices can automatically generate their own IP addresses upon connecting to a network without needing a DHCP server.
- *Built-in Security (IPsec):* While optional in IPv4, IPsec support is fundamentally integrated into the IPv6 protocol suite, encouraging end-to-end encryption and authentication.

- **6to4 Tunneling (2 Marks):**

- *Mechanism:* 6to4 allows isolated IPv6 networks (islands) to communicate over an IPv4 network (the ocean) without explicit tunnel setup. It encapsulates IPv6 packets directly inside IPv4 packets (Protocol 41). It relies on public IPv4 addresses and assigns a specific IPv6 prefix (2002::/16) mathematically derived from the router's public IPv4 address. It generally fails if the router is behind a NAT device.

- **Teredo Tunneling (2 Marks):**

- *Mechanism:* Teredo is explicitly designed to bypass NAT. Because standard IPv4 NAT drops Protocol 41 packets, Teredo encapsulates IPv6 packets inside IPv4 UDP datagrams. This allows hosts located behind NAT devices (like home routers) to establish tunnels and access the IPv6 Internet seamlessly.

Q4. b) Compare the filtering criteria and defensive mechanisms of basic Packet Filtering Firewalls versus Stateful Inspection Firewalls. (7 Marks)

- **Basic Packet Filtering Firewalls (3.5 Marks):**

- *Filtering Criteria (1.5 Marks):* Operates at the Network and Transport layers (Layers 3 and 4). It filters traffic based solely on static header information: source/destination IP addresses, ports, and protocols.
- *Defensive Mechanisms & Limits (2 Marks):* It treats every single packet independently and is entirely stateless. Because it does not remember past packets, it is easily tricked by IP spoofing or malicious packets that pretend to be part of an ongoing connection (e.g., an attacker sending unsolicited TCP ACK packets).

- **Stateful Inspection Firewalls (3.5 Marks):**

- *Filtering Criteria (1.5 Marks):* Operates primarily at Layers 3 and 4 but can inspect up to the Session layer (Layer 5). It filters based on static header information *plus* the dynamic context of the connection state.
- *Defensive Mechanisms (2 Marks):* It maintains a dynamic "State Table" that actively tracks the establishment, progress, and teardown of network connections (like the TCP three-way handshake). If an incoming packet claims to belong to an established session, the firewall checks the state table. If no such valid session exists, the packet is instantly dropped, effectively neutralizing spoofing and out-of-sequence attacks.

Q5. a) Contrast Mandatory Access Control (MAC) with Discretionary Access Control (DAC), specifically highlighting how each model handles the threat of malware execution. (7 Marks)

- **Discretionary Access Control (DAC) (3 Marks):**

- *Concept:* The owner or creator of a file has full discretion to grant or revoke access permissions (read, write, execute) to other users via Access Control Lists (ACLs).
- *Malware Threat Handling:* DAC is highly vulnerable to malware. If a user accidentally executes a malicious program (like a Trojan or Ransomware), that malware automatically inherits the exact same permissions as the user. The malware can freely read, modify, or encrypt any data that the user has the discretion to access, making containment nearly impossible.

- **Mandatory Access Control (MAC) (4 Marks):**

- *Concept:* Access policies are strictly enforced by the operating system based on centralized rules, security clearances, and data classification labels (e.g., Top Secret, Confidential). Users and data owners cannot alter these core security policies.
- *Malware Threat Handling:* MAC severely restricts malware execution. Even if a user with a "Top Secret" clearance executes malware, the malware is confined by the system's strict labeling rules. For instance, the system will prevent the malware from writing malicious code to system directories or down-grading classified data to a public folder, effectively containing the "blast radius" regardless of the user's intent or permissions.

Q5. b) Describe how Digital Signatures provide non-repudiation and explain the structure of the Hierarchical and Mesh PKI Trust Models. (8 Marks)

- **Digital Signatures and Non-repudiation (4 Marks):**

- *How it works:* A sender hashes their message and encrypts that hash using their personal *Private Key*. The receiver decrypts the signature using the sender's *Public Key* and verifies the hash.
- *Non-repudiation:* Because the Private Key is securely held only by the sender, successful decryption with their Public Key mathematically proves that the sender (and no one else) authorized the message. Consequently, the sender cannot legally or technically deny (repudiate) having sent the message or signed the document.

- **Hierarchical PKI Trust Model (2 Marks):**

- *Structure:* A centralized, inverted-tree structure containing a single, universally trusted Root Certificate Authority (CA) at the top. The Root CA signs certificates for Subordinate CAs, which in turn issue certificates to end-users. Trust flows strictly from the top down. While easy to scale, the Root CA represents a single point of failure.

- **Mesh PKI Trust Model (2 Marks):**

- *Structure:* A decentralized, peer-to-peer structure (often called a Web of Trust or cross-certification model). Multiple independent CAs (or individuals) issue certificates and mutually cross-certify one another. There is no single central Root CA. While this eliminates a single point of failure and allows for flexible trust paths, it is mathematically complex to manage and scale for large environments.

You Asked 

Q6. a) Detail the five macro processing steps of the SHA-512 algorithm, including the specific rules for padding and length appending. (8 Marks)b) Explain the concepts, components, and strategic intelligence goals of Honey pots, Honey nets, and Honey clients. (7 Marks)

Q7. a) Define and clearly differentiate the propagation and execution methods of a Virus, Worm, Trojan Horse, and Rootkit. (8 Marks)b) Outline the three-pronged Mobile Device Security Strategy, specifying the controls necessary for Device, Traffic, and Barrier security. (7 Marks)

Gemini 3.1 Pro Extended

Here are the detailed answers for the final questions, structured to align directly with the requested marking distributions.

Section B (Continued)

Q6. a) Detail the five macro processing steps of the SHA-512 algorithm, including the specific rules for padding and length appending. (8 Marks)

- **Step 1: Append Padding Bits (2 Marks)** The original message is padded so that its length is congruent to $896 \pmod{1024}$. Padding is always added, even if the message is already the desired length. The padding consists of a single 1 bit followed by the necessary number of 0 bits (ranging from 1 to 1024 bits of padding).
- **Step 2: Append Length (1.5 Marks)** A 128-bit block is appended to the padded message. This 128-bit block represents the exact length of the *original*, unpadded message in bits. After Steps 1 and 2, the total message length is an exact multiple of 1024 bits.

- **Step 3: Initialize Hash Buffer (1.5 Marks)** The algorithm initializes an intermediate hash value buffer. For SHA-512, this consists of eight 64-bit registers (labeled A through H). These registers are initialized with specific, hardcoded hexadecimal fractional parts of the square roots of the first eight prime numbers.
- **Step 4: Process Message in 1024-bit Blocks (2 Marks)** The padded message is processed in sequential 1024-bit blocks. This is the core of the algorithm. Each block goes through 80 rounds of complex mathematical and logical operations (using non-linear functions, modular addition, and bitwise shifts). Each round uses a 64-bit word derived from a "message schedule" and a unique constant derived from the cube roots of the first 80 prime numbers.
- **Step 5: Output Final Hash (1 Mark)** After all 1024-bit blocks have been sequentially processed and added to the cumulative hash buffers, the final step concatenates the eight 64-bit registers (A + B + C + D + E + F + G + H) to produce the definitive 512-bit message digest.

Q6. b) Explain the concepts, components, and strategic intelligence goals of Honeypots, Honeynets, and Honeyclients. (7 Marks)

- **Honeypots (2.5 Marks)**
 - *Concept/Component:* A decoy system or server purposefully designed to look like a vulnerable, high-value target (e.g., an unpatched database or web server) to attract cyberattackers. It contains no legitimate business value or production data.
 - *Strategic Goal:* To act as an early warning system, divert malicious traffic away from critical assets, and log attacker methodologies, signatures, and zero-day exploits for threat intelligence.
- **Honeynets (2.5 Marks)**
 - *Concept/Component:* A larger-scale, architectural deployment consisting of two or more honeypots on a network, complete with decoy routers, firewalls, and fake data.
 - *Strategic Goal:* To simulate an entire corporate infrastructure. This allows security teams to observe lateral movement, multi-stage attack campaigns, and network-wide compromise tactics that a single honeypot cannot capture.
- **Honeyclients (2 Marks)**
 - *Concept/Component:* Unlike traditional honeypots that wait passively for inbound connections, honeyclients are active tools (like instrumented web browsers). They proactively crawl the internet, visit websites, and interact with servers.
 - *Strategic Goal:* To detect client-side attacks, primarily malicious web servers hosting drive-by downloads or browser-based exploits, mapping out malicious infrastructure from the victim's perspective.

Q7. a) Define and clearly differentiate the propagation and execution methods of a Virus, Worm, Trojan Horse, and Rootkit. (8 Marks)

- **Virus (2 Marks)**
 - *Propagation:* Attaches itself to legitimate host files (like .exe or macro-enabled documents). It spreads only when the infected host file is transferred to another system.
 - *Execution:* Requires explicit human interaction (e.g., a user clicking a malicious attachment or running an infected program) to execute its payload.
- **Worm (2 Marks)**
 - *Propagation:* Entirely self-replicating and self-propagating. It actively scans networks for vulnerabilities and spreads from machine to machine independently, requiring no host file.
 - *Execution:* Executes autonomously upon finding a vulnerable system. It requires absolutely zero human interaction to trigger or spread.

- **Trojan Horse (2 Marks)**

- *Propagation*: Relies heavily on social engineering. It does not self-replicate. It must be disguised as a desirable or benign piece of software (like a game or utility) to trick users into downloading it.
- *Execution*: Executes when the tricked user intentionally installs or runs the disguised program, thereby unknowingly triggering the hidden malicious payload.

- **Rootkit (2 Marks)**

- *Propagation*: Rarely spreads on its own; it is usually dropped by a primary infection (like a Trojan or worm) after initial access is achieved.
- *Execution*: Executes deep within the operating system, often at the kernel level. Its primary function is not necessarily to cause immediate damage, but to subvert the OS to explicitly hide the presence of itself and other malware from antivirus scanners and system administrators.

Q7. b) Outline the three-pronged Mobile Device Security Strategy, specifying the controls necessary for Device, Traffic, and Barrier security. (7 Marks)

- **Device Security (2.5 Marks)** Focuses on physically and logically securing the endpoint hardware itself in case it is lost, stolen, or compromised.
 - *Controls*: Mandatory screen locks with strong PINs/biometrics, full-disk encryption (FDE), remote wipe/brick capabilities, restricting application permissions, disabling jailbreaking/rooting, and enforcing Mobile Device Management (MDM) enrollment.
- **Traffic Security (2.5 Marks)** Focuses on protecting the confidentiality and integrity of the data while it is in transit between the mobile device and corporate servers or the internet.
 - *Controls*: Enforcing Virtual Private Network (VPN) usage on untrusted networks, requiring TLS/HTTPS for all application communication, disabling automatic connections to open public Wi-Fi hotspots, and encrypting email syncs.
- **Barrier Security (2 Marks)** Focuses on creating secure boundaries to isolate corporate data from personal data and the broader internet, effectively containing potential breaches.
 - *Controls*: Application sandboxing (preventing apps from sharing data without permission), containerization (creating a strictly segregated, encrypted workspace for corporate apps and data on a personal BYOD device), and deploying Mobile Application Management (MAM) to control specific apps rather than the whole device.

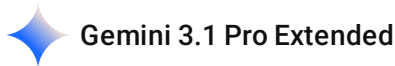
You Asked 

Section A (Compulsory)

Q1. Answer all the following sub-questions. (Total 30 Marks)

- Distinguish between the scope of Cybersecurity and Information Security (InfoSec). (3 Marks)
- Describe the three distinct lifecycle phases managed by the OSI Session Layer. (4 Marks)
- What is the architectural difference and purpose of an Intrusion Prevention System (IPS) compared to a traditional Intrusion Detection System (IDS)? (3 Marks)
- Explain the concept of a Demilitarized Zone (DMZ) in an enterprise firewall architecture and list what systems typically reside there. (4 Marks)
- Outline the operational steps involved in Lamport's Hash Chain for generating One-Time Passwords (OTPs). (4 Marks)
- Compare the maximum speed, frequency bands, and the underlying multiplexing/antenna technologies (OFDM vs MIMO) of the 802.11a and 802.11n wireless standards. (4 Marks)
- Why

is the "Order of Volatility" a critical procedural concept during digital forensics evidence collection? (4 Marks)h) Distinguish between the overarching goals of a Risk Assessment and a detailed Risk Analysis. (4 Marks)



Here are the answers for Section A, structured to align directly with the requested marking weight for each question.

Section A (Compulsory)

a) Distinguish between the scope of Cybersecurity and Information Security (InfoSec). (3 Marks)

- **Information Security (InfoSec) (1.5 Marks):** This has a broader scope. It is concerned with protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction to provide confidentiality, integrity, and availability (the CIA triad). It covers data in *all* forms, including digital, physical (paper records), and human knowledge.
- **Cybersecurity (1.5 Marks):** This is a specific subset of InfoSec. Its scope is strictly limited to protecting *digital* assets, electronic data, networks, and IT infrastructure from cyber-attacks, electronic interception, and unauthorized digital access.

b) Describe the three distinct lifecycle phases managed by the OSI Session Layer. (4 Marks)

- **Establishment (1.5 Marks):** The phase where a connection is negotiated and set up between two communicating applications. This includes authenticating users, establishing access rights, and assigning unique session IDs.
- **Management and Maintenance (1.5 Marks):** The phase governing the active exchange of data. The Session Layer controls the dialogue (simplex, half-duplex, or full-duplex) and inserts synchronization points (checkpoints) into the data stream so that if a crash occurs, the transmission can resume from the last checkpoint rather than starting over.
- **Termination (1 Mark):** The phase where the session is gracefully disconnected and local resources are released once the communication is successfully completed.

c) What is the architectural difference and purpose of an Intrusion Prevention System (IPS) compared to a traditional Intrusion Detection System (IDS)? (3 Marks)

- **IDS Architecture & Purpose (1.5 Marks):** An IDS is deployed *out-of-band* (passively). It monitors a copy of network traffic (e.g., via a span port). Its sole purpose is to detect malicious activity, log it, and send alerts. It cannot physically stop the attack.
- **IPS Architecture & Purpose (1.5 Marks):** An IPS is deployed *in-line* (actively) within the direct flow of network traffic. Its purpose is to not only detect malicious activity but to immediately drop the offending packets, reset the connection, or block the IP address before the attack reaches its target.

d) Explain the concept of a Demilitarized Zone (DMZ) in an enterprise firewall architecture and list what systems typically reside there. (4 Marks)

- **Concept (2 Marks):** A DMZ is a physical or logical subnetwork that exposes an organization's external-facing, untrusted services to a larger untrusted network (usually the Internet). It acts as a buffer zone. If an external attacker compromises a server in the DMZ, they still do not have direct access to the highly secure, internal corporate network.
- **Typical Systems (2 Marks):** Web servers (HTTP/HTTPS), Mail servers (SMTP), Domain Name System (DNS) servers, and File Transfer Protocol (FTP) servers.

e) Outline the operational steps involved in Lamport's Hash Chain for generating One-Time Passwords (OTPs). (4 Marks)

- **Step 1: Initialization (1 Mark):** A user selects a secret password (seed) w and an integer n .

- **Step 2: Generation (1 Mark):** A cryptographic hash function H is applied to the seed n times to create a sequence: $H^n(w), H^{n-1}(w), \dots, H(w)$. The server securely stores the final hash, $H^n(w)$.
- **Step 3: Client Authentication (1 Mark):** For the first login, the user's client calculates and sends the next-to-last hash in the chain: $x = H^{n-1}(w)$.
- **Step 4: Server Verification (1 Mark):** The server hashes the received value x once ($H(x)$) and compares it to its stored value $H^n(w)$. If they match, access is granted, and the server replaces its stored value with x for use in the next login sequence. The system works backward through the chain.

f) Compare the maximum speed, frequency bands, and the underlying multiplexing/antenna technologies (OFDM vs MIMO) of the 802.11a and 802.11n wireless standards. (4 Marks)

- **802.11a (2 Marks):** Offers a maximum theoretical speed of 54 Mbps and operates exclusively on the 5 GHz frequency band. It relies on standard **OFDM** (Orthogonal Frequency-Division Multiplexing) to divide the signal across multiple subcarriers for transmission.
- **802.11n (2 Marks):** Offers a significantly higher maximum speed of up to 600 Mbps and operates on both 2.4 GHz and 5 GHz bands (dual-band). Its major advancement is the use of **MIMO** (Multiple Input, Multiple Output) technology, utilizing multiple antennas at both the transmitter and receiver to send multiple data streams simultaneously (spatial multiplexing), alongside enhanced OFDM.

g) Why is the "Order of Volatility" a critical procedural concept during digital forensics evidence collection? (4 Marks)

- **Concept (2 Marks):** The Order of Volatility is the standardized rule dictating that investigators must collect digital evidence starting from the most fragile, highly volatile data down to the most stable, non-volatile data.
- **Critical Importance (2 Marks):** If standard procedures are ignored (e.g., if an investigator simply unplugs a server to seize the hard drive), all volatile data—such as running malicious processes, active network connections, clipboard contents, and RAM data—will be instantly and permanently destroyed. Following the order ensures vital temporal evidence is preserved.

h) Distinguish between the overarching goals of a Risk Assessment and a detailed Risk Analysis. (4 Marks)

- **Risk Assessment (2 Marks):** A broad, strategic process aimed at identifying, categorizing, and prioritizing risks to organizational assets and operations. Its goal is to provide leadership with a high-level (often qualitative) understanding of the organization's overall security posture to guide policy and focus.
- **Risk Analysis (2 Marks):** A deeper, tactical step performed within the assessment framework. Its goal is to meticulously examine specific identified risks to calculate exact probabilities of occurrence and quantify potential financial impacts (e.g., calculating Single Loss Expectancy or Annualized Loss Expectancy). This quantitative data is used to justify the specific costs of implementing countermeasures.

You Asked 

Section B (Attempt any 4 questions)
Each question carries 15 marks.

Q2. a) Define the core components of the OSI Security Architecture (Security Attacks, Security Mechanisms, and Security Services) as specified by ITU-T Recommendation X.800. (7 Marks) b) Explain the TCP 3-way handshake process used to establish a connection and detail how an attacker exploits this mechanism in a SYN Flood attack. (8 Marks)

Q3. a) Describe the AES Key Expansion algorithm loop, detailing how it eliminates symmetry and the specific role of the complex, non-linear function 'g'. (8 Marks)b) Explain why standard modular exponentiation is inefficient in RSA and describe how the decryption process is optimized using the Chinese Remainder Theorem (CRT) and Fermat's Theorem. (7 Marks)

Gemini 3.1 Pro Extended

Here are the detailed answers for the selected Section B questions, structured to align directly with the requested marking weight for each item.

Section B

Q2. a) Define the core components of the OSI Security Architecture (Security Attacks, Security Mechanisms, and Security Services) as specified by ITU-T Recommendation X.800. (7 Marks)

- **Security Attacks (2 Marks):** Any action that compromises the security of information owned by an organization. ITU-T X.800 divides these broadly into *Passive attacks* (where the attacker simply monitors or eavesdrops on data without altering it) and *Active attacks* (where the attacker actively alters data, disrupts systems, or creates false streams).
- **Security Mechanisms (2.5 Marks):** A specific operational process, software protocol, or hardware device designed to detect, prevent, or recover from a security attack. Mechanisms are the actual tools used to implement security. Examples include cryptographic algorithms (encryption), digital signatures, access control lists, and data integrity checks.
- **Security Services (2.5 Marks):** A high-level processing or communication service that enhances the security of data processing systems and information transfers, effectively countering security attacks. A service makes use of one or more *security mechanisms* to provide a specific security guarantee. Examples include Confidentiality, Authentication, Data Integrity, Non-repudiation, and Access Control.

Q2. b) Explain the TCP 3-way handshake process used to establish a connection and detail how an attacker exploits this mechanism in a SYN Flood attack. (8 Marks)

- **The TCP 3-Way Handshake (4 Marks):** To establish a reliable connection, TCP uses a three-step process:
 1. **SYN:** The client initiates the connection by sending a TCP segment with the SYN (Synchronize) flag set, containing a random initial sequence number, to the server.
 2. **SYN-ACK:** The server receives the SYN, allocates temporary system resources to track this pending connection (a "half-open" state), and replies with a segment that has both the SYN and ACK (Acknowledge) flags set.
 3. **ACK:** The client receives the SYN-ACK and responds with a final ACK packet. The connection is now fully established, and data transfer can begin.
- **Exploitation via SYN Flood Attack (4 Marks):** * *The Exploit:* An attacker maliciously sends a massive volume of SYN packets to the target server, often using spoofed (fake) source IP addresses.
 - *The Impact:* The server dutifully responds to each spoofed SYN with a SYN-ACK and allocates memory for a half-open connection, waiting for the final ACK. Because the source IPs are fake, the final ACKs never arrive.
 - *The Result:* The server's backlog queue for pending connections fills up entirely. Once the queue is full, the server is forced to drop all new, legitimate connection requests, resulting in a Denial of Service (DoS).

Q3. a) Describe the AES Key Expansion algorithm loop, detailing how it eliminates symmetry and the specific role of the complex, non-linear function 'g'. (8 Marks)

- **AES Key Expansion Loop (4 Marks):** The AES Key Expansion algorithm takes the initial cipher key (e.g., 128 bits) and expands it into a much longer linear array of 32-bit words to provide a unique Round Key for every round of the cipher. For AES-128, it generates 44 words (equivalent to 11 round keys of 128 bits each). It iterates in a loop where a new word $W[i]$ is generally created by simply XORing the previous word $W[i - 1]$ with the word four positions back $W[i - 4]$.
- **Eliminating Symmetry and the Role of Function 'g' (4 Marks):** If the expansion relied solely on simple XOR operations, the derived keys would be highly symmetrical and vulnerable to related-key attacks. To destroy this mathematical symmetry, every 4th word (in AES-128) is passed through a complex, non-linear function called 'g' before the XOR step. The 'g' function consists of three critical operations:
 1. **RotWord:** A one-byte circular left shift of the 32-bit word, which breaks byte alignment and spatial symmetry.
 2. **SubWord:** Each byte of the word is substituted using the non-linear AES S-box, providing essential cryptographic confusion.
 3. **Rcon (Round Constant) XOR:** The result is XORed with a round-dependent constant. Because the constant changes predictably but uniquely every round, it completely eliminates symmetry between different rounds.

Q3. b) Explain why standard modular exponentiation is inefficient in RSA and describe how the decryption process is optimized using the Chinese Remainder Theorem (CRT) and Fermat's Theorem. (7 Marks)

- **Inefficiency of Standard Modular Exponentiation (2 Marks):** In standard RSA, decrypting a ciphertext C requires computing $M \equiv C^d \pmod{n}$. The private exponent d and the modulus n are incredibly large numbers (typically 2048 or 4096 bits long). Performing exponentiation with such massive numbers requires enormous computational overhead, making the decryption process practically very slow.
- **Optimization using CRT and Fermat's Theorem (5 Marks):**
 - Instead of performing one massive calculation modulo n (where $n = p \times q$), the Chinese Remainder Theorem (CRT) allows the system to split the decryption into two smaller, parallel calculations modulo the prime factors p and q .
 - By applying **Fermat's Little Theorem**, the massive private key exponent d is reduced to two much smaller exponents:
 - $d_p = d \pmod{p - 1}$
 - $d_q = d \pmod{q - 1}$
 - The system then computes two intermediate values:
 - $M_p \equiv C^{d_p} \pmod{p}$
 - $M_q \equiv C^{d_q} \pmod{q}$
 - Finally, these two smaller results are mathematically recombined using the CRT to yield the final plaintext M .
 - **Result:** Because the computational complexity of modular exponentiation scales cubically with the bit-length of the numbers, processing two half-sized equations is approximately four times faster than processing one full-sized equation, vastly accelerating RSA decryption.

You Asked 

Q4. a) Differentiate between the deployment of Host-based IDS (HIDS) and Network-based IDS (NIDS), and critically compare Misuse Detection with Anomaly Detection methodologies. (8 Marks) b) Discuss the operational benefits of Single Sign-On (SSO) systems alongside their primary interoperability and security vulnerabilities (the Single Point of Failure risk). (7 Marks)

Q5. a) Explain the functionality of the IPSec protocol suite, specifically focusing on

the differences between AH and ESP, and the purpose of Security Associations (SAs). (8 Marks)b) Compare the encapsulation capabilities, networking scope, and inherent security features of the Point-to-Point Tunneling Protocol (PPTP) versus the Layer 2 Tunneling Protocol (L2TP). (7 Marks)

Gemini 3.1 Pro Extended

Here are the detailed answers for your questions, structured to align precisely with the requested marking weight for each item.

Section B

Q4. a) Differentiate between the deployment of Host-based IDS (HIDS) and Network-based IDS (NIDS), and critically compare Misuse Detection with Anomaly Detection methodologies. (8 Marks)

- **Deployment Differences (4 Marks):**
 - *Host-based IDS (HIDS) (2 Marks):* Deployed directly on individual endpoints, servers, or host machines. It monitors internal host activities, such as system logs, file integrity changes, local network traffic, and system calls. It is blind to the broader network.
 - *Network-based IDS (NIDS) (2 Marks):* Deployed at strategic network chokepoints (e.g., switches using span ports, or network taps) to monitor traffic moving across the network segments. It analyzes packet flows, headers, and payloads in transit, but has no visibility into what happens inside the endpoint itself.
- **Methodology Comparison (4 Marks):**
 - *Misuse Detection (Signature-based) (2 Marks):* Functions like traditional antivirus. It compares observed events against a strict database of known malicious attack signatures. It is highly accurate at catching known threats (low false positives) but completely blind to zero-day attacks or novel variants (high false negatives).
 - *Anomaly Detection (Behavior-based) (2 Marks):* Uses statistical modeling or machine learning to establish a "normal" baseline of behavior. It flags any significant deviation from this baseline as an attack. It is highly effective at detecting novel, zero-day attacks (low false negatives), but because network traffic is inherently erratic, it suffers from a high rate of false alarms (high false positives).

Q4. b) Discuss the operational benefits of Single Sign-On (SSO) systems alongside their primary interoperability and security vulnerabilities (the Single Point of Failure risk). (7 Marks)

- **Operational Benefits (3.5 Marks):** SSO drastically improves the user experience by reducing "password fatigue"; users only need to memorize one strong set of credentials rather than dozens. Operationally, it vastly reduces helpdesk overhead related to password resets, and it allows IT departments to instantly provision or de-provision user access to all enterprise applications simultaneously from a central directory.
- **Vulnerabilities & Interoperability (3.5 Marks):**
 - *Interoperability:* Integrating legacy, custom-built, or non-web applications into modern SSO frameworks (like SAML, OAuth, or OIDC) is often technically complex or impossible without significant rewriting.
 - *The Single Point of Failure (SPOF):* SSO consolidates risk. If the central Identity Provider (IdP) or authentication server experiences downtime, users are locked out of *all* federated services simultaneously. Furthermore, if an attacker successfully compromises a user's single set of SSO credentials, they instantly gain lateral, authorized access to every system, app, and data repository that user has rights to.

Q5. a) Explain the functionality of the IPSec protocol suite, specifically focusing on the differences between AH and ESP, and the purpose of Security Associations (SAs). (8 Marks)

- **IPSec Functionality (1 Mark):** IPSec is a framework operating at the Network Layer (Layer 3) that secures IP communications by authenticating and encrypting each IP packet of a communication session.
- **AH vs. ESP Differences (4 Marks):**
 - *Authentication Header (AH) (2 Marks):* Provides data origin authentication, data integrity, and anti-replay protection. It signs the packet payload and a significant portion of the IP header. Crucially, AH provides *no confidentiality*—the data payload is transmitted in plaintext.
 - *Encapsulating Security Payload (ESP) (2 Marks):* Provides all the authentication and integrity benefits of AH, but its primary distinction is that it also provides *data confidentiality* through encryption of the payload. For this reason, ESP is the standard choice for modern VPNs.
- **Security Associations (SAs) (3 Marks):** An SA is a strictly one-way (simplex) logical connection established between two IPSec nodes. Its purpose is to define and store the specific security parameters for that connection, such as the cryptographic algorithms used, the session keys, and whether AH or ESP is applied. Because an SA is one-way, a standard bidirectional IPSec VPN requires the establishment of at least two independent SAs.

Q5. b) Compare the encapsulation capabilities, networking scope, and inherent security features of the Point-to-Point Tunneling Protocol (PPTP) versus the Layer 2 Tunneling Protocol (L2TP). (7 Marks)

- **Encapsulation Capabilities (2 Marks):**
 - *PPTP:* Encapsulates Point-to-Point Protocol (PPP) frames into IP datagrams for transmission over the network, primarily utilizing Generic Routing Encapsulation (GRE).
 - *L2TP:* A hybrid of PPTP and Cisco's L2F. It encapsulates PPP frames inside UDP (User Datagram Protocol) packets, making it highly efficient for traversing firewalls and NAT devices.
- **Networking Scope (2 Marks):**
 - *PPTP:* Is strictly limited to transporting data over IP networks.
 - *L2TP:* Is highly versatile; it is designed to operate over IP, but can also run over non-IP networks like Frame Relay, X.25, and ATM.
- **Inherent Security Features (3 Marks):**
 - *PPTP:* Includes built-in encryption through Microsoft Point-to-Point Encryption (MPPE). However, this encryption is fundamentally flawed, deeply outdated, and widely considered compromised by modern security standards.
 - *L2TP:* Contains absolutely zero inherent encryption or robust authentication. By itself, it only creates a tunnel. Therefore, L2TP must always be paired with a security protocol—almost universally IPSec (creating L2TP/IPSec)—to provide confidentiality and data integrity.

You Asked 

Q6. a) Explain the mechanism of Role-Based Access Control (RBAC) and evaluate its structural variations, including Core RBAC, Hierarchical RBAC, and Separation of Duties (Static vs. Dynamic). (8 Marks) b) Trace the evolution of password-based authentication defenses, analyzing the vulnerabilities of plaintext storage, simple hashing, and the mitigations provided by password salting. (7 Marks)

Q7. a) Evaluate the severe operational and security risks associated with an

unmanaged (decentralized) patch management model versus the standard methodologies of centralized patch management. (7 Marks)b) Describe the hierarchy of organizational security policies (Master, Issue-Specific, System-Specific) and define the supporting framework components (Standards, Guidelines, Procedures, Baselines) required to enforce them. (8 Marks)

Gemini 3.1 Pro Extended

Here are the detailed answers for the final questions, structured to align directly with the requested marking distributions.

Section B (Continued)

Q6. a) Explain the mechanism of Role-Based Access Control (RBAC) and evaluate its structural variations, including Core RBAC, Hierarchical RBAC, and Separation of Duties (Static vs. Dynamic). (8 Marks)

- **Mechanism of RBAC (2 Marks):** Unlike Discretionary Access Control (where users own data) or Mandatory Access Control (based on clearance labels), RBAC assigns permissions to specific organizational **Roles** rather than individual users. Users are then assigned to these roles based on their job functions. This drastically simplifies administration; if an employee changes departments, administrators simply change their role assignment rather than manually modifying dozens of individual file permissions.
- **Core RBAC (2 Marks):** This is the foundational model. It establishes the basic many-to-many relationships: a single user can have multiple roles, a single role can have multiple users, and a single role can be granted multiple system permissions. It also introduces the concept of a "session," where a user activates a subset of their assigned roles at any given time.
- **Hierarchical RBAC (2 Marks):** This variation introduces role inheritance, mapping directly to an organization's chain of command. Senior roles mathematically inherit all the access permissions of junior roles beneath them. For example, a "Chief Medical Officer" role automatically inherits all permissions granted to the "Attending Physician" role, plus their own exclusive executive permissions.
- **Separation of Duties (SoD) (2 Marks):** A critical fraud-prevention mechanism ensuring no single individual has enough power to execute a sensitive transaction alone.
 - **Static SoD:** A strict configuration where a user cannot be authorized for two mutually exclusive roles at the same time (e.g., a user cannot be assigned both the "Purchasing" role and the "Accounts Payable" role).
 - **Dynamic SoD:** A user is technically allowed to hold two conflicting roles, but the system prevents them from activating both roles during the *same* login session to complete a transaction.

Q6. b) Trace the evolution of password-based authentication defenses, analyzing the vulnerabilities of plaintext storage, simple hashing, and the mitigations provided by password salting. (7 Marks)

- **Plaintext Storage (2 Marks):**
 - *Mechanism:* Storing the exact, readable characters of a user's password directly in the database.
 - *Vulnerability:* This is a catastrophic security failure. If an attacker gains read access to the database via SQL injection or a compromised backup, every single user's password is instantly and fully exposed, leading to immediate system-wide compromise and credential stuffing attacks elsewhere.
- **Simple Hashing (2.5 Marks):**
 - *Mechanism:* Running the password through a one-way mathematical function (like SHA-256) and storing only the resulting fixed-length string (the hash). When a user logs in, the system hashes their input and compares it to the stored hash.

- **Vulnerability:** While better than plaintext, it is highly vulnerable to **Rainbow Table attacks** (massive, pre-computed databases of passwords and their corresponding hashes). Furthermore, if two users have the exact same password, their hashes will be identical, allowing an attacker to easily identify common passwords and spot patterns across the database.
- **Password Salting (2.5 Marks):**
 - **Mechanism/Mitigation:** The system generates a long, unique, random string (the "salt") for every individual user. This salt is appended to the plaintext password *before* the hashing function is applied.
 - **Defense:** Salting completely destroys the effectiveness of Rainbow Tables because the attacker would have to compute a brand new, massive table for every single unique salt in the database, which is computationally infeasible. Additionally, even if two users choose the exact same password, their unique salts guarantee that their stored hashes will look completely different, hiding user behavior patterns.

Q7. a) Evaluate the severe operational and security risks associated with an unmanaged (decentralized) patch management model versus the standard methodologies of centralized patch management. (7 Marks)

- **Unmanaged (Decentralized) Patch Management (3.5 Marks):**
 - **Model:** Relies on individual end-users or local department heads to download and install operating system and application updates on their own machines.
 - **Risks:** This creates a highly fragmented, inconsistent security posture. Users routinely delay, ignore, or disable updates because they find the reboots disruptive. This leaves massive windows of vulnerability where critical systems are exposed to known, easily preventable exploits (like self-propagating ransomware or worms). Furthermore, it is impossible for IT security teams to audit compliance, as there is no central visibility into which machines are patched and which are vulnerable.
- **Centralized Patch Management (3.5 Marks):**
 - **Model:** Updates are managed, downloaded, tested, and pushed to all endpoints via automated, central deployment servers (e.g., WSUS, SCCM, or cloud-based MDM) controlled by the IT security team.
 - **Methodologies & Benefits:** Patches are first deployed to a staging environment to test for compatibility, preventing a bad update from crashing business-critical applications (a common risk in unmanaged models). Once verified, the updates are forcefully pushed to endpoints during scheduled maintenance windows, ensuring uniform security across the enterprise. It also provides immediate, automated reporting for regulatory compliance audits.

Q7. b) Describe the hierarchy of organizational security policies (Master, Issue-Specific, System-Specific) and define the supporting framework components (Standards, Guidelines, Procedures, Baselines) required to enforce them. (8 Marks)

- **Hierarchy of Organizational Security Policies (4 Marks):**
 - **Master / Enterprise Information Security Policy (EISP):** The highest-level strategic document, drafted by executive leadership (C-Suite). It defines the overall vision, scope, direction, and authority of the corporate security program. It rarely changes and does not mention specific technologies.
 - **Issue-Specific Security Policy (ISSP):** Mid-level documents addressing specific areas of concern, behaviors, or technologies across the organization. Examples include an Acceptable Use Policy (AUP), Bring Your Own Device (BYOD) policy, or Email Security Policy.
 - **System-Specific Security Policy (SSSP):** Highly technical, granular rules governing the configuration, access control, and management of a specific piece of equipment or software (e.g., the exact access control lists on the main corporate firewall).
- **Supporting Framework Components (4 Marks):**
 - **Standards (1 Mark):** Mandatory, specific, and measurable requirements that must be met to ensure compliance with a policy. (e.g., "All user passwords must be a minimum of 14 characters").

- **Baselines (1 Mark):** The absolute minimum acceptable level of security configuration required for a system, device, or application to be allowed onto the corporate network.
- **Procedures (1 Mark):** Detailed, step-by-step tactical instructions or checklists explaining exactly how to accomplish a specific task in compliance with the policies and standards (e.g., the exact 10-step process for an IT admin to provision a new user account).
- **Guidelines (1 Mark):** Recommended, non-mandatory best practices or advice designed to help users and administrators understand how to better comply with standards when strict procedures do not apply.

You Asked 

Section A (Compulsory)

Q1. Answer all the following sub-questions. (Total 30 Marks)

- (Theory) Differentiate between AES-128, AES-192, and AES-256 in terms of their key size (in bytes) and the number of processing rounds required. (3 Marks)
- (Numerical) In a symmetric cryptosystem, every pair of communicating users requires a unique shared key. Calculate the total number of secure keys required if an organization scales its network to 45 users. (4 Marks)
- (Theory) Explain the concept of the "Avalanche Effect." Why is a ~50% bit change the cryptographic ideal for a block cipher? (4 Marks)
- (Numerical) A highly decentralized enterprise utilizes a Mesh PKI Trust Model connecting 8 separate Root Certificate Authorities (CAs). Calculate the exact number of cross-certificates required to establish trust across the entire mesh. (3 Marks)

Gemini 3.1 Pro Extended

Here are the answers to the questions, structured to directly align with the requested marking weight for each item.

Section A (Compulsory)

a) (Theory) Differentiate between AES-128, AES-192, and AES-256 in terms of their key size (in bytes) and the number of processing rounds required. (3 Marks)

- **AES-128 (1 Mark):** Utilizes a key size of 16 bytes (128 bits) and requires 10 processing rounds.
- **AES-192 (1 Mark):** Utilizes a key size of 24 bytes (192 bits) and requires 12 processing rounds.
- **AES-256 (1 Mark):** Utilizes a key size of 32 bytes (256 bits) and requires 14 processing rounds.

b) (Numerical) In a symmetric cryptosystem, every pair of communicating users requires a unique shared key. Calculate the total number of secure keys required if an organization scales its network to 45 users. (4 Marks)

- **Formula (2 Marks):** To find the total number of unique pairs in a network of n users, the formula is: $Keys = \frac{n(n-1)}{2}$
- **Calculation (2 Marks):** Given $n = 45$ users: $Keys = \frac{45(45-1)}{2}$ $Keys = \frac{45 \times 44}{2}$ $Keys = 45 \times 22$ $Keys = 990$
Result: The organization will require a total of **990 secure keys**.

c) (Theory) Explain the concept of the "Avalanche Effect." Why is a ~50% bit change the cryptographic ideal for a block cipher? (4 Marks)

- **Concept (2 Marks):** The Avalanche Effect is a desirable property in cryptography where a microscopic change in the input (changing just a single bit of either the plaintext or the encryption key) results in an avalanche of changes in the output ciphertext.
- **The 50% Ideal (2 Marks):** A ~50% bit flip is the cryptographic ideal because it maximizes entropy and perfectly simulates randomness. If the change was significantly lower (e.g., 10%) or higher (e.g., 90%), the output would retain a statistical correlation to the input. Attackers could exploit this correlation using differential cryptanalysis to deduce the key. At exactly 50%, an attacker cannot determine if a bit flipped due to a pattern or pure chance, rendering statistical attacks useless.

d) (Numerical) A highly decentralized enterprise utilizes a Mesh PKI Trust Model connecting 8 separate Root Certificate Authorities (CAs). Calculate the exact number of cross-certificates required to establish trust across the entire mesh. (3 Marks)

- **Formula (1.5 Marks):** In a fully meshed PKI model, trust is mutual and directional. Every CA must issue a certificate to, and receive a certificate from, every other CA. For n CAs, the formula for total cross-certificates is: $Certificates = n(n - 1)$
- **Calculation (1.5 Marks):** Given $n = 8$ Root CAs: $Certificates = 8(8 - 1)$ $Certificates = 8 \times 7$
 $Certificates = 56$ **Result:** A total of **56 cross-certificates** are required to establish trust across the entire mesh.

You Asked 

- e) (Numerical) The SHA-512 algorithm requires an input message to be padded. If a sender transmits a message exactly 1500 bits long, calculate the exact number of padding bits required and state the size of the appended length field. (4 Marks)
- f) (Theory) Define False Rejection Rate (FRR) and False Acceptance Rate (FAR) in the context of evaluating biometric accuracy. (4 Marks)
- g) (Numerical) In an RSA public-key cryptosystem, a user selects primes $p = 5$ and $q = 11$, and a public exponent $e = 3$. Calculate the private exponent d . (4 Marks)
- h) (Theory) Distinguish between the filtering mechanism of a basic Packet Filtering Firewall and a Stateful Inspection Firewall. (4 Marks)

Gemini 3.1 Pro Extended

Here are the answers to the final sub-questions, structured to directly align with the requested marking weight for each item.

Section A (Compulsory)

e) (Numerical) The SHA-512 algorithm requires an input message to be padded. If a sender transmits a message exactly 1500 bits long, calculate the exact number of padding bits required and state the size of the appended length field. (4 Marks)

- **Padding Calculation (2 Marks):** SHA-512 processes messages in 1024-bit blocks. Before the length field is added, the padded message length must be congruent to $896 \pmod{1024}$.
 - Current message length = 1500 bits.
 - The next length that satisfies this condition after 1500 is 1920 bits (since $1920 \pmod{1024} = 896$).
 - Required padding = $1920 - 1500 = 420$.

◦ Therefore, **420 padding bits** are required (a single 1 bit followed by 419 0 bits).

- **Length Field Size (2 Marks):** The SHA-512 algorithm strictly appends a **128-bit** length field at the very end of the padded message to indicate the original message size (bringing the total final length to 2048 bits, which perfectly forms two 1024-bit blocks).

f) (Theory) Define False Rejection Rate (FRR) and False Acceptance Rate (FAR) in the context of evaluating biometric accuracy. (4 Marks)

- **False Rejection Rate (FRR) (2 Marks):** Also known as a Type I error. It is the statistical probability that a biometric system fails to recognize and incorrectly rejects access to a legitimate, authorized user. A high FRR causes significant friction and user frustration.
- **False Acceptance Rate (FAR) (2 Marks):** Also known as a Type II error. It is the statistical probability that a biometric system incorrectly authenticates and grants access to an unauthorized, illegitimate user. A high FAR represents a critical security vulnerability.

g) (Numerical) In an RSA public-key cryptosystem, a user selects primes $p = 5$ and $q = 11$, and a public exponent $e = 3$. Calculate the private exponent d . (4 Marks)

- **Step 1: Calculate Euler's Totient $\phi(n)$ (1 Mark):** $\phi(n) = (p - 1) \times (q - 1)$ $\phi(n) = (5 - 1) \times (11 - 1) = 4 \times 10 = 40$
- **Step 2: Set up the Congruence Equation (1 Mark):** The private exponent d must satisfy the relation $d \times e \equiv 1 \pmod{\phi(n)}$. $3d \equiv 1 \pmod{40}$
- **Step 3: Solve for d (2 Marks):** We need to find an integer d such that $3d$ is 1 greater than a multiple of 40 ($3d = 40k + 1$).
 - If $k = 1$: $3d = 41$ (41 is not divisible by 3).
 - If $k = 2$: $3d = 81$.
 - $81/3 = 27$.
 - Therefore, the private exponent $d = 27$.

h) (Theory) Distinguish between the filtering mechanism of a basic Packet Filtering Firewall and a Stateful Inspection Firewall. (4 Marks)

- **Basic Packet Filtering Firewall (2 Marks):** Operates primarily at Layer 3 (Network Layer) and makes allow/deny decisions on individual packets in complete isolation. It filters statelessly using only static header information, such as source/destination IP addresses and port numbers, meaning it cannot distinguish if a packet is part of a legitimate ongoing conversation or a spoofed attack.
- **Stateful Inspection Firewall (2 Marks):** Operates at Layers 3 and 4, but actively monitors the dynamic state of active network connections (e.g., the TCP 3-way handshake). It maintains a "state table" in memory. Incoming packets are not only checked against static rules but must also match an established, valid session in the state table to be allowed through, effectively blocking spoofed or out-of-sequence packets.

You Asked 

Section B (Attempt any 4 questions)

Each question carries 15 marks.

Q2. a) (Numerical & Practical) Using the AES MixColumns matrix transformation over the finite field $GF(2^8)$, demonstrate the mathematical process (using shifts and XORs) to compute the multiplication of $\{02\} \cdot \{87\}$ and $\{03\} \cdot \{03\}$

{6E}\\$. (7 Marks)

b) (Theory) Describe the AES Key Expansion algorithm. Specifically, explain the purpose of the complex function 'g' and the Round Constant (Rcon) in preventing key schedule symmetry. (8 Marks)



Section B

Q2. a) (Numerical & Practical) Using the AES MixColumns matrix transformation over the finite field $GF(2^8)$, demonstrate the mathematical process (using shifts and XORs) to compute the multiplication of $\{02\} \cdot \{87\}$ and $\{03\} \cdot \{6E\}$. (7 Marks)

To perform multiplication in the Galois Field $GF(2^8)$, AES uses specific rules based on irreducible polynomials (specifically, $x^8 + x^4 + x^3 + x + 1$, represented in hex as $\{1B\}$):

- **Multiplication by $\{02\}$ (2 Marks):** This is executed as a 1-bit logical left shift of the binary value. If the original Most Significant Bit (MSB) before the shift was 1, the shifted result must be XORed ($\oplus$) with the irreducible polynomial $\{1B\}$ (binary 00011011). If the MSB was 0, no XOR is needed.
- **Multiplication by $\{03\}$:** This is executed by breaking it down into a combination of $\{02\}$ and $\{01\}$ (which is just the original value): $\{03\} \cdot X = (\{02\} \cdot X) \oplus X$.

1. Calculation of $\{02\} \cdot \{87\}$ (2.5 Marks)

- Convert $\{87\}$ to binary: 10000111
- Observe the MSB: The MSB is 1.
- Perform a 1-bit left shift (discard the MSB, append a 0 at the end): $Shift(10000111) = 00001110$
- Because the original MSB was 1, XOR the result with $\{1B\}$ (00011011): $00001110 \oplus 00011011 = 00010101$
- Convert the binary result back to hexadecimal: $00010101 = \{15\}$
- **Result:** $\{02\} \cdot \{87\} = \{15\}$

2. Calculation of $\{03\} \cdot \{6E\}$ (2.5 Marks)

- **Step A: Calculate $\{02\} \cdot \{6E\}$**
 - Convert $\{6E\}$ to binary: 01101110
 - Observe the MSB: The MSB is 0.
 - Perform a 1-bit left shift: $Shift(01101110) = 11011100$
 - Because the original MSB was 0, no conditional XOR is required. The intermediate result is 11011100 (or $\{DC\}$).
- **Step B: XOR with the original value**
 - According to the $\{03\}$ rule: $\{03\} \cdot \{6E\} = (\{02\} \cdot \{6E\}) \oplus \{6E\}$
 - XOR the intermediate result with the original binary value of $\{6E\}$: $11011100 \oplus 01101110 = 10110010$
- Convert the final binary result back to hexadecimal: $10110010 = \{B2\}$
- **Result:** $\{03\} \cdot \{6E\} = \{B2\}$

Q2. b) (Theory) Describe the AES Key Expansion algorithm. Specifically, explain the purpose of the complex function 'g' and the Round Constant (Rcon) in preventing key schedule symmetry. (8 Marks)

- **AES Key Expansion Overview (2 Marks):** The AES Key Expansion algorithm takes the initial user-provided cipher key (128, 192, or 256 bits) and mathematically stretches it to generate a linear array of 32-bit words. These words are grouped to form unique "Round Keys" for every processing round of the cipher. For example, AES-128 requires 44 words in total (4 words for the initial AddRoundKey, plus 4 words for each of the 10 rounds). The expansion primarily relies on simple XOR operations between previously generated words: $W[i] = W[i - 1] \oplus W[i - 4]$.
- **The Purpose and Mechanics of the 'g' Function (3 Marks):** If the key schedule relied exclusively on simple XOR operations, the resulting round keys would be highly symmetrical and mathematically related, making the cipher vulnerable to related-key attacks. To destroy this symmetry, every 4th word (in AES-128) is intercepted and passed through a complex, non-linear function called 'g' before the XOR step. The 'g' function breaks symmetry using three operations:
 1. **RotWord:** A 1-byte circular left shift of the 32-bit word. This destroys byte alignment and spatial symmetry.
 2. **SubWord:** Each of the four bytes is substituted using the non-linear AES S-box. This injects severe cryptographic confusion and non-linearity into the key schedule.
 3. **Rcon XOR:** The result is XORed with a Round Constant.
- **The Role of the Round Constant (Rcon) (3 Marks):** The Round Constant (Rcon) is a predefined array of 32-bit values where only the rightmost byte varies per round (based on powers of x in $GF(2^8)$). Its specific cryptographic purpose is to eliminate round-to-round symmetry.
 - Without Rcon, if a user provided a completely uniform key (e.g., all zeros or repeated bytes), the key expansion might generate identical round keys for multiple rounds.
 - By XORing a constant that changes predictably but uniquely *every single round*, Rcon ensures that the behavior of the 'g' function is fundamentally different in Round 1 than it is in Round 10. This guarantees that even highly symmetrical or weak initial keys will produce completely disparate, pseudo-random round keys, effectively neutralizing structural attacks.

You Asked 

Q3. a) (Numerical) Perform a full RSA key generation, encryption, and decryption cycle. Given primes $p = 17$ and $q = 11$, and a public exponent $e = 7$:
 Compute the modulus n and the totient $\phi(n)$.
 Verify the private key exponent is $d = 23$.
 Encrypt the plaintext message $M = 88$ and show the resulting ciphertext C . (8 Marks)

b) (Theory) Explain the multiplicative mathematical property that makes RSA vulnerable to a Chosen Ciphertext Attack (CCA). Detail how Optimal Asymmetric Encryption Padding (OAEP) is used as a countermeasure. (7 Marks)

 Gemini 3.1 Pro Extended

Here are the detailed answers for Question 3, structured to directly align with the requested marking weight for each part.

Section B

Q3. a) (Numerical) Perform a full RSA key generation, encryption, and decryption cycle. Given primes $p = 17$ and $q = 11$, and a public exponent $e = 7$: (8 Marks)

- **1. Compute the modulus n and the totient $\phi(n)$ (2 Marks):**
 - The modulus n is calculated as $p \times q$: $n = 17 \times 11 = 187$
 - Euler's totient function $\phi(n)$ is calculated as $(p - 1) \times (q - 1)$: $\phi(n) = (17 - 1) \times (11 - 1) \phi(n) = 16 \times 10 = 160$
- **2. Verify the private key exponent is $d = 23$ (2 Marks):**
 - The private exponent d must satisfy the relation $d \times e \equiv 1 \pmod{\phi(n)}$.
 - Substituting the known values, we check if $23 \times 7 \equiv 1 \pmod{160}$: $23 \times 7 = 161 \equiv 1 \pmod{160}$
 - *Result:* Because the remainder is 1, $d = 23$ is mathematically verified as the correct private key.
- **3. Encrypt the plaintext message $M = 88$ and show the resulting ciphertext C (4 Marks):**
 - The encryption formula is $C \equiv M^e \pmod{n}$.
 - Substituting the values: $C \equiv 88^7 \pmod{187}$.
 - To solve this efficiently, we use the method of successive squaring (modular exponentiation):
 - $88^1 \equiv 88 \pmod{187}$
 - $88^2 = 7744 \equiv 77 \pmod{187}$
 - $88^4 = 77^2 = 5929 \equiv 132 \pmod{187}$
 - Now, combine the powers to reach 88^7 (since $7 = 4 + 2 + 1$):
 - $88^7 = 88^4 \times 88^2 \times 88^1 \pmod{187}$
 - $88^7 \equiv (132 \times 77 \times 88) \pmod{187}$
 - Multiplying step-by-step:
 - $132 \times 77 = 10164 \equiv 66 \pmod{187}$
 - $66 \times 88 = 5808 \equiv 11 \pmod{187}$
 - *Result:* The final ciphertext is $C = 11$. (Note: The receiver would decrypt this using $11^{23} \pmod{187}$ to recover the plaintext 88.)

Q3. b) (Theory) Explain the multiplicative mathematical property that makes RSA vulnerable to a Chosen Ciphertext Attack (CCA). Detail how Optimal Asymmetric Encryption Padding (OAEP) is used as a countermeasure. (7 Marks)

- **The Multiplicative Vulnerability to CCA (4 Marks):**
 - "Textbook RSA" possesses a property called **multiplicative homomorphism**. This means that multiplying two ciphertexts together and decrypting the result yields the product of their respective plaintexts. Mathematically: $E(M_1) \times E(M_2) \equiv E(M_1 \times M_2) \pmod{n}$.
 - *The Attack:* An attacker intercepts a legitimate target ciphertext C . They choose a random number r , encrypt it using the victim's public key to get r^e , and multiply it by the target ciphertext to create a modified, "blinded" ciphertext: $C' = C \times r^e \pmod{n}$.
 - The attacker sends C' to the victim (or an automated decryption oracle). The oracle successfully decrypts it and returns the modified plaintext $M' = M \times r \pmod{n}$. The attacker then simply multiplies M' by the modular inverse of their random number (r^{-1}) to recover the original secret plaintext M , completely bypassing the private key.
- **Optimal Asymmetric Encryption Padding (OAEP) as a Countermeasure (3 Marks):**
 - *Mechanism:* OAEP acts as a secure formatting layer applied *before* the RSA encryption step. It uses a Feistel network structure along with secure cryptographic hash functions to inject a random seed and structured padding into the

plaintext block. This makes the encryption probabilistic—encrypting the same message multiple times will result in completely different ciphertexts.

- **Defense:** Because OAEP strictly formats the mathematical structure of the plaintext, it destroys the multiplicative homomorphism of RSA. If an attacker intercepts an OAEP-padded ciphertext and attempts the multiplication trick ($C \times r^e$), the resulting decrypted data will completely fail the strict formatting and padding checks. The system will safely reject the manipulated data and return a generic error, preventing the attacker from extracting any useful information.

You Asked 

Q4. a) (Numerical) During the Diffie-Hellman Key Exchange within the SSH Transport Layer Protocol, the Client computes $e = g^x \pmod p$ and the Server computes $f = g^y \pmod p$. Assuming a safe prime $p = 11$, generator $g = 2$, the Client's secret $x = 3$, and the Server's secret $y = 4$, calculate the public values e and f , and prove that both sides arrive at the same shared master key K . (8 Marks)

b) (Theory) Outline the five macro processing steps of the SHA-512 algorithm. Explain how the message schedule introduces heavy diffusion by deriving 80 words (W_0 to W_{79}) from a 1024-bit block. (7 Marks)

Gemini 3.1 Pro Extended

Here are the detailed answers for Question 4, structured to directly align with the requested marking weight for each part.

Section B

Q4. a) (Numerical) During the Diffie-Hellman Key Exchange within the SSH Transport Layer Protocol, the Client computes $e = g^x \pmod p$ and the Server computes $f = g^y \pmod p$. Assuming a safe prime $p = 11$, generator $g = 2$, the Client's secret $x = 3$, and the Server's secret $y = 4$, calculate the public values e and f , and prove that both sides arrive at the same shared master key K . (8 Marks)

- **Step 1: Calculate the Client's public value e (2 Marks)**
 - Formula: $e = g^x \pmod p$
 - Substitute: $e = 2^3 \pmod{11}$
 - Calculate: $e = 8 \pmod{11}$
 - **Result:** Client's public value $e = 8$
- **Step 2: Calculate the Server's public value f (2 Marks)**
 - Formula: $f = g^y \pmod p$
 - Substitute: $f = 2^4 \pmod{11}$
 - Calculate: $f = 16 \pmod{11}$
 - **Result:** Server's public value $f = 5$
- **Step 3: Client computes the shared master key K (2 Marks)**
 - The Client receives f from the Server and uses its own secret x .

- Formula: $K = f^x \pmod{p}$
- Substitute: $K = 5^3 \pmod{11}$
- Calculate: $5^3 = 125$. To find $125 \pmod{11}$, divide 125 by 11 ($11 \times 11 = 121$). $125 - 121 = 4$.
- **Client's Key:** $K = 4$
- **Step 4: Server computes the shared master key K (2 Marks)**
 - The Server receives e from the Client and uses its own secret y .
 - Formula: $K = e^y \pmod{p}$
 - Substitute: $K = 8^4 \pmod{11}$
 - Calculate using successive squaring:
 - $8^2 = 64 \equiv 9 \pmod{11}$
 - $8^4 = (8^2)^2 \equiv 9^2 \pmod{11}$
 - $9^2 = 81$. To find $81 \pmod{11}$, divide 81 by 11 ($11 \times 7 = 77$). $81 - 77 = 4$.
 - **Server's Key:** $K = 4$
- **Conclusion:** Both the Client and the Server have independently computed the exact same shared master key, $K = 4$, using only public exchanges and their own private secrets.

Q4. b) (Theory) Outline the five macro processing steps of the SHA-512 algorithm. Explain how the message schedule introduces heavy diffusion by deriving 80 words (W_0 to W_{79}) from a 1024-bit block. (7 Marks)

- **Part 1: The Five Macro Processing Steps (4 Marks)**
 1. **Append Padding Bits:** The original message is padded so its length becomes congruent to 896 $\pmod{1024}$. Padding always begins with a single 1 bit followed by the necessary number of 0 bits.
 2. **Append Length:** A 128-bit block is appended to the padded message. This block contains the exact binary length of the original, unpadded message. The total message length is now a perfect multiple of 1024 bits.
 3. **Initialize Hash Buffer:** Eight 64-bit registers (labeled A through H) are initialized. These hold the intermediate and final hash states and are seeded with predetermined constants (the fractional parts of the square roots of the first eight prime numbers).
 4. **Process Message in 1024-bit Blocks:** This is the core compression function. Each 1024-bit block is processed sequentially through 80 complex cryptographic rounds, updating the A-H registers.
 5. **Output Final Hash:** After all blocks are processed and their outputs added to the cumulative buffers, the eight 64-bit registers are concatenated to form the definitive 512-bit message digest.
- **Part 2: Message Schedule Derivation and Diffusion (3 Marks)**
 - **Derivation:** At the start of Step 4, the 1024-bit block is divided into sixteen 64-bit words (W_0 through W_{15}). These directly feed the first 16 rounds. To generate the remaining 64 words for rounds 16 through 79, SHA-512 uses the mathematical formula: $W_t = \sigma_1(W_{t-2}) + W_{t-7} + \sigma_0(W_{t-15}) + W_{t-16}$
 - **Heavy Diffusion:** The σ_0 and σ_1 functions are highly complex, consisting of right-rotations (circular shifts) and right-shifts of the bits. By forcing W_t to be the sum of four distinct, mathematically scrambled prior words, the schedule ensures that any single bit change in the original 1024-bit block rapidly propagates across all subsequent words. By the time the schedule reaches W_{79} , every word is a profoundly scrambled, irreversible mixture of the original message bits. This guarantees massive diffusion *before* the data even enters the main round operations.

Q5. a) (Practical Scenario) Analyze the TCP 3-way handshake process. Detail how an attacker exploits this specific connection mechanism to execute a SYN Flood Denial of Service (DoS) attack, and describe the architectural mitigation strategy. (7 Marks)

b) (Theory) Compare the OSI and TCP/IP Reference Models. Specifically, map the 4 layers of TCP/IP to the 7 layers of the OSI model and explain the logical process of data encapsulation as a message moves down the stack. (8 Marks)

Gemini 3.1 Pro Extended

Here are the detailed answers for Question 5, structured to directly align with the requested marking weight for each part.

Section B

Q5. a) (Practical Scenario) Analyze the TCP 3-way handshake process. Detail how an attacker exploits this specific connection mechanism to execute a SYN Flood Denial of Service (DoS) attack, and describe the architectural mitigation strategy. (7 Marks)

- **The TCP 3-Way Handshake Process (2 Marks):** To establish a reliable, stateful connection, TCP utilizes a three-step protocol:
 1. **SYN:** The client initiates the connection by sending a TCP segment with the SYN (Synchronize) flag set, containing a randomized sequence number.
 2. **SYN-ACK:** The server receives the request, allocates temporary memory in its backlog queue to track this "half-open" connection, and replies with a SYN-ACK flag.
 3. **ACK:** The client receives the SYN-ACK and sends a final ACK (Acknowledge) flag back to the server. The connection is fully established.
- **The SYN Flood Exploit (3 Marks):**
 - *Execution:* The attacker intentionally disrupts the handshake by bombarding the target server with thousands of initial SYN packets, often using spoofed (falsified) source IP addresses.
 - *Impact:* The server faithfully responds to every single SYN packet with a SYN-ACK and allocates memory for each in its pending connection queue. Because the source IPs are fake or the attacker is intentionally ignoring the server, the final ACK step is never completed.
 - *Denial of Service:* The server's backlog queue quickly reaches maximum capacity with these incomplete, half-open connections. Once the queue is full, the server drops all new, legitimate connection requests, resulting in a complete Denial of Service.
- **Architectural Mitigation Strategies (2 Marks):**
 - **SYN Cookies:** The most common mitigation. Instead of allocating memory immediately upon receiving a SYN, the server calculates a cryptographic hash (the "cookie") based on the connection details and sends it in the SYN-ACK. The server drops the connection state. If the client is legitimate and sends the final ACK, it echoes the cookie back, allowing the server to mathematically verify and reconstruct the connection without having held it in memory.
 - **Firewall/IPS SYN Proxying:** An in-line security appliance intercepts the SYN packets and completes the 3-way handshake on behalf of the server. Only fully verified, completed connections are passed to the actual backend

server.

Q5. b) (Theory) Compare the OSI and TCP/IP Reference Models. Specifically, map the 4 layers of TCP/IP to the 7 layers of the OSI model and explain the logical process of data encapsulation as a message moves down the stack. (8 Marks)

- **Mapping the Reference Models (4 Marks):** The OSI model uses a strict 7-layer approach, while the more pragmatic TCP/IP model condenses these into 4 distinct layers.
 1. **Application Layer (TCP/IP):** Maps directly to the **Application (Layer 7)**, **Presentation (Layer 6)**, and **Session (Layer 5)** of the OSI model. It handles high-level protocols (HTTP, FTP, DNS), data formatting, encryption, and dialogue control.
 2. **Transport Layer (TCP/IP):** Maps identically to the **Transport (Layer 4)** of the OSI model. It is responsible for end-to-end communication, reliability, and flow control (using TCP or UDP).
 3. **Internet Layer (TCP/IP):** Maps directly to the **Network (Layer 3)** of the OSI model. It handles logical addressing (IP addresses) and routing packets across different networks.
 4. **Network Access / Link Layer (TCP/IP):** Maps to the **Data Link (Layer 2)** and **Physical (Layer 1)** of the OSI model. It handles hardware addressing (MAC addresses), physical framing, and the actual transmission of raw bits over the physical medium (cable, fiber, wireless).
- **The Logical Process of Data Encapsulation (4 Marks):** Encapsulation is the process of wrapping data with essential protocol information at each layer as it travels down the TCP/IP stack toward the physical network.
 - **Application Layer:** The user creates data (e.g., an email or web request). This raw data is passed down to the Transport layer.
 - **Transport Layer:** The TCP or UDP protocol receives the data and adds a Transport header (containing Source and Destination Ports, sequence numbers, and checksums). The resulting encapsulated data unit is called a **Segment**.
 - **Internet Layer:** The IP protocol receives the Segment and adds a Network header (containing the Source and Destination logical IP addresses). The resulting encapsulated data unit is called a **Packet** (or Datagram).
 - **Network Access Layer:** The hardware protocols (like Ethernet) receive the Packet and add a Data Link header (containing Source and Destination MAC addresses) and a trailer (containing a Frame Check Sequence for error detection). The resulting encapsulated data unit is called a **Frame**.
 - **Physical Transmission:** Finally, the Frame is converted into raw binary bits (electrical impulses, light pulses, or radio waves) and transmitted across the physical medium.

You Asked 

Q6. a) (Theory) Describe the Demilitarized Zone (DMZ) architecture. Explain the specific filtering purposes of the external firewall versus the internal firewall, and list the types of servers that must be placed inside the DMZ. (8 Marks)

b) (Theory) Differentiate between Misuse Detection (Signature-Based) and Anomaly Detection (Behavior-Based) methodologies in Intrusion Detection Systems (IDS). Discuss the inherent trade-offs regarding False Positives and False Negatives. (7 Marks)

Here are the detailed answers for Question 6, structured to directly align with the requested marking weight for each part.

Section B

Q6. a) (Theory) Describe the Demilitarized Zone (DMZ) architecture. Explain the specific filtering purposes of the external firewall versus the internal firewall, and list the types of servers that must be placed inside the DMZ. (8 Marks)

- **DMZ Architecture (2 Marks):** A Demilitarized Zone (DMZ) is a physical or logical subnetwork that serves as a secure buffer or neutral zone between an organization's trusted internal network and an untrusted external network (typically the Internet). It prevents external users from gaining direct access to the internal network.
- **External Firewall Filtering Purpose (2 Marks):** Placed directly between the Internet and the DMZ. Its primary purpose is to filter inbound internet traffic, allowing only specific, necessary requests (e.g., HTTP traffic on port 80 or HTTPS on port 443) to reach the servers located inside the DMZ, while silently dropping all other unsolicited traffic.
- **Internal Firewall Filtering Purpose (2 Marks):** Placed between the DMZ and the internal corporate network. Its filtering rules are exceptionally strict. Its purpose is to completely block any inbound traffic originating from the Internet or the DMZ from accessing the internal network. This ensures that even if an attacker successfully compromises a server inside the DMZ, they remain blocked from pivoting into the highly sensitive internal corporate network. It generally only allows outbound traffic from the internal network to the DMZ/Internet and the corresponding return traffic.
- **Servers Placed inside the DMZ (2 Marks):** Any service that requires direct interaction with the public internet must be placed in the DMZ. Common examples include:
 - Web Servers (HTTP/HTTPS)
 - Mail Servers (SMTP/IMAP)
 - Domain Name System (DNS) Servers
 - File Transfer Protocol (FTP) Servers
 - Proxy Servers or VPN Endpoints

Q6. b) (Theory) Differentiate between Misuse Detection (Signature-Based) and Anomaly Detection (Behavior-Based) methodologies in Intrusion Detection Systems (IDS). Discuss the inherent trade-offs regarding False Positives and False Negatives. (7 Marks)

- **Misuse Detection (Signature-Based) (2.5 Marks):** This methodology operates much like a traditional antivirus program. It continuously compares observed network traffic, packet payloads, or system logs against a predefined database of known attack signatures, malicious bit sequences, or specific vulnerability exploit patterns. If a match is found, an alert is triggered.
- **Anomaly Detection (Behavior-Based) (2.5 Marks):** This methodology does not look for specific attacks. Instead, it uses statistical analysis, heuristics, or machine learning to monitor the network over time and establish a baseline profile of "normal" behavior (e.g., average bandwidth usage, typical login times, standard protocol usage). It triggers an alert whenever current network activity significantly deviates from this established baseline.
- **The Trade-offs: False Positives vs. False Negatives (2 Marks):**
 - **Misuse Detection Trade-off:** Because it relies on exact matches, it produces very few **False Positives** (it rarely mistakes legitimate traffic for an attack). However, it suffers from a high rate of **False Negatives** (it will completely miss novel "zero-day" attacks or heavily modified malware because no signature exists for them yet).
 - **Anomaly Detection Trade-off:** Because it relies on deviations rather than known threats, it is excellent at detecting brand-new, zero-day attacks, resulting in very few **False Negatives**. However, because network traffic is inherently erratic (e.g., a sudden legitimate spike in web traffic or a user logging in from a new timezone), it suffers from a high

rate of **False Positives**. This can easily lead to "alert fatigue" for security analysts who have to investigate benign anomalies.

You Asked 

Q7. a) (Practical Scenario) Your organization is transitioning from an unmanaged, decentralized patch management system to a centralized model. Evaluate the severe security, bandwidth, and operational risks of the unmanaged model, and describe the agent-based deployment strategy. (7 Marks)

b) (Theory) Detail the ElGamal Digital Signature Scheme. Explain the mathematical steps involved in key generation and signing a message, and discuss how digital signatures solve the issue of repudiation. (8 Marks)

Gemini 3.1 Pro Extended

Here are the detailed answers for Question 7, structured to directly align with the requested marking weight for each part.

Section B (Continued)

Q7. a) (Practical Scenario) Your organization is transitioning from an unmanaged, decentralized patch management system to a centralized model. Evaluate the severe security, bandwidth, and operational risks of the unmanaged model, and describe the agent-based deployment strategy. (7 Marks)

- **Risks of an Unmanaged (Decentralized) Model (4 Marks):**
 - **Security Risks:** End-users are responsible for their own updates. Users frequently delay, ignore, or disable updates to avoid disruptive reboots. This results in "Swiss cheese" security, where a network is highly fragmented and riddled with known vulnerabilities. IT lacks visibility and cannot mathematically prove compliance during an audit.
 - **Bandwidth Risks:** In an unmanaged model, every single endpoint independently downloads identical multi-gigabyte update files directly from external vendor servers (e.g., Microsoft or Apple) over the internet. This redundant downloading severely congests the organization's WAN/Internet link, choking critical business traffic.
 - **Operational Risks:** Updates are not pre-tested. If a vendor releases a flawed patch, it is immediately installed on end-user machines, potentially causing "Blue Screens of Death" or breaking proprietary legacy software. IT must then manually troubleshoot hundreds of broken machines individually.
- **Agent-Based Deployment Strategy (3 Marks):**
 - **Mechanism:** In a centralized, agent-based model, a lightweight software agent is permanently installed on every endpoint device.
 - **Operation:** A central patch management server acts as the single point of download from the internet, drastically saving WAN bandwidth. The administrator tests the patch in a sandbox, approves it, and pushes a policy to the agents.
 - **Enforcement:** The local agents securely pull the approved patch from the central server, enforce the installation silently in the background (regardless of user preference), and report exact success/failure telemetry back to the central console.

Q7. b) (Theory) Detail the ElGamal Digital Signature Scheme. Explain the mathematical steps involved in key generation and signing a message, and discuss how digital signatures solve the issue of repudiation. (8 Marks)

- **Phase 1: Key Generation (3 Marks):**

1. The user chooses a large prime number p and a generator g of the multiplicative group $\mathbb{Z}_p^*$.
2. The user selects a secret, random integer x (where $1 < x < p - 1$) to serve as their **Private Key**.
3. The user computes their public key component y using the formula: $y = g^x \pmod{p}$
 - **Result:** The **Public Key** is published as (p, g, y) , and the **Private Key** is kept entirely secret as x .

- **Phase 2: Signing a Message (3 Marks):** To sign a specific message M :

1. The user hashes the message to create a fixed-size digest $m = H(M)$ (ensuring $0 \leq m < p - 1$).
2. The user generates a random, ephemeral, secret integer k (where $1 < k < p - 1$) that must be strictly coprime to $p - 1$ (meaning $\gcd(k, p - 1) = 1$). A new k must be generated for every single signature.
3. The user computes the first part of the signature, r : $r = g^k \pmod{p}$
4. The user computes the second part of the signature, s , using the modular multiplicative inverse of k modulo $(p - 1)$:
 $s = (m - x \cdot r) \cdot k^{-1} \pmod{p - 1}$
 - **Result:** The final digital signature appended to the message is the pair (r, s) .

- **Solving the Issue of Repudiation (2 Marks):**

- Repudiation occurs when a sender falsely denies having sent or authorized a message.
- Digital signatures explicitly solve this because the generation of the parameter s mathematically requires the exact value of the sender's Private Key x .
- Since the private key x is securely held *only* by the sender, any successful mathematical verification of the (r, s) signature by a receiver (using the sender's public key y) provides undeniable, cryptographic proof that the legitimate sender authorized the specific message digest m . Therefore, the sender cannot legally or technically repudiate it.